

5 实验五 网络安全与防火墙实验

网络安全旨在保护网络系统及其数据免受破坏、篡改或泄露，确保网络服务的连续性和可靠性。主要目标包括：保密性（防止未经授权的访问）、完整性（确保数据在传输和存储中不被篡改）和可用性（保障授权用户能够随时访问网络资源）等。

常见的网络安全威胁有：恶意软件（如病毒、蠕虫、木马等）、网络攻击（如 DDoS、中间人攻击、SQL 注入等）、数据泄露（未经授权的数据访问或泄露）和社会工程（如钓鱼攻击，通过欺骗获取敏感信息）等。

防火墙是网络安全的重要组成部分，通过访问控制、网络隔离、防御攻击和日志记录等措施防护网络安全。类型主要有包过滤防火墙、状态检测防火墙、代理防火墙及下一代防火墙（集成入侵检测、应用控制等）等。

5.1 实验目的

- 1) 理解网络安全的基本概念、核心目标及常见的网络安全威胁；
- 2) 掌握防火墙的工作原理及安全域、NAT 和 SSLVPN 的配置使用。

5.2 实验内容

- 1) 利用防火墙进行组网，通过安全域划分和规则设置进行网络管理；
- 2) 在防火墙上设置 NAT，掌握其配置与应用；
- 3) 在防火墙上设置 SSLVPN，测试并分析 web 接入模式与 ip 接入模式的异同和优缺点。

5.3 实验原理

5.3.1 安全域

传统防火墙的安全控制策略通常基于报文的入接口和出接口进行配置。具体来说，进入和离开接口的流量需要根据接口上指定方向的策略规则进行过滤，这种基于接口的策略配置方式存在配置复杂、维护困难和灵活性不足等问题。为了克服传统策略配置方式的局限性，基于安全域（Security Zone）的安全控制策略配置方式应运而生。通过安全域间的策略控制，减少策略数量，提高策略执行效率。

安全域是网络安全管理中的一个重要逻辑概念，用于将安全需求相同的接口进行分类和统一管理。通过划分安全域，网络管理员可以更高效地实施域间安全策略，确保网络资源的安全性和可控性。安全域通常应用于防火墙、路由器等安全防护设备，用于管理不同网络区域之间

的访问控制。安全域具有简化管理、增强安全性、提高灵活性等优势。

在大多数安全防护设备中，系统预定义了以下缺省安全域，这些安全域不能被删除：

- **Local**（本地域）：代表设备本身的接口，用于管理设备自身的流量（如管理流量、设备间通信等）；
- **Trust**（可信域）：内部网络区域，通常包含企业内部用户和受信任的设备（如企业内部办公网络、数据中心等）；
- **Untrust**（非可信域）：代表外部网络区域，通常包含不可信的互联网或其他外部网络（如互联网接入、外部用户访问等）；
- **DMZ**（隔离区）：逻辑上和物理上都与内部网络和外部网络分离的区域，用于放置需要被公共访问的设备（如 Web 服务器、FTP 服务器、邮件服务器等）；
- **Management**（管理域）专门用于设备管理的区域，通常包含管理接口和访问控制策略（如设备配置、监控、维护等）。

合理划分和配置安全域，能够显著提升网络的安全性和管理效率。创建安全域后，设备上各接口的报文转发遵循以下规则：

- 一个安全域中的接口与一个不属于任何安全域的接口之间的报文，会被丢弃；
- 属于同一个安全域的各接口之间的报文缺省会被丢弃；
- 安全域之间的报文由域间策略进行安全检查，并根据检查结果放行或丢弃。若域间策略不存在或不生效，则报文会被丢弃；
- 非安全域的接口之间的报文被丢弃；
- 目的地址或源地址为本机的报文，缺省会被丢弃，若该报文与域间策略匹配，则由域间策略进行安全检查，并根据检查结果放行或丢弃。

5.3.2 NAT

NAT（Network Address Translation，网络地址转换）是一种网络技术，用于将私有网络的 IP 地址转换为公有网络的 IP 地址，从而实现私有网络与公有网络之间的通信。NAT 的主要目的是解决 IPv4 地址不足的问题，同时提高网络的安全性。

NAT 通过在路由器或防火墙上维护一个地址转换表，将私有 IP 地址映射为公有 IP 地址。当数据包从私有网络发送到公有网络时，NAT 会修改数据包的源 IP 地址；当数据包从公有网络返回时，NAT 会修改数据包的目的 IP 地址。主要类型有：静态 NAT（Static NAT）、动态 NAT（Dynamic NAT）和 PAT（Port Address Translation，端口地址转换）等。

NAT 的优点：

- **节省公有 IP 地址**：通过 NAT，多个私有 IP 地址可以共享一个或少量公有 IP 地址，缓解 IPv4 地址不足的问题；
- **提高网络安全性**：NAT 隐藏了内部网络的真实 IP 地址，使得外部网络无法直接访问内部设备，增强了网络的安全性；

- 简化网络管理：NAT 允许内部网络使用私有 IP 地址，无需为每台设备分配公有 IP 地址，降低了网络管理的复杂度。

NAT 的缺点：

- 影响端到端通信：NAT 修改了数据包的 IP 地址和端口号，可能影响某些需要端到端通信的应用（如 VoIP、P2P 等）；
- 增加网络延迟：NAT 需要对数据包进行地址转换，可能增加网络延迟；
- 配置复杂度高：在某些场景下（如静态 NAT 或复杂网络环境），NAT 的配置可能较为复杂。

NAT 的典型应用场景：

- 企业网络：企业内部用户通过 NAT 访问互联网；
- 家庭网络：家庭路由器通过 NAT 实现多台设备共享一个公有 IP 地址；
- 服务器暴露：通过静态 NAT 将内部服务器暴露到互联网，供外部用户访问。

5.3.3 SSL VPN

SSL VPN（Secure Sockets Layer Virtual Private Network）是一种基于 SSL/TLS 协议的远程接入技术，旨在为移动办公人员（即远程用户）提供安全、便捷的企业内网访问服务。通过 SSL VPN，远程用户可以在不可靠的公共网络中建立加密的 SSL 数据通道，直接连接到企业内网，访问内部资源，从而显著提高工作效率。SSL VPN 的广泛应用为远程办公和全球办公室的建立提供了必要的技术支持。

SSL VPN 的核心特点：

- 安全性：SSL VPN 提供安全的加密连接，只有经过身份认证的用户才能访问企业内网资源，确保数据传输的机密性和完整性。
- 可控性：SSL VPN 能够对加密隧道进行细分，使终端用户可以同时访问互联网和企业内网资源，并实现精细化的访问控制。
- 权限管理：SSL VPN 支持细化的接入控制功能，可以根据用户角色分配不同的访问权限，实现灵活的权限管理。
- 广泛接入：SSL VPN 几乎不受接入位置限制，用户可以从任何互联网接入设备或远程位置访问企业内网资源。
- 兼容性：SSL VPN 基于标准的 TCP/UDP 协议传输，能够穿透 NAT 设备、代理防火墙和状态检测防火墙，确保用户在任何网络环境下都能顺利接入。

SSL VPN 的接入模式：

- 无客户端 Web 接入模式：用户无需安装 VPN 客户端，只需通过支持 SSL 的浏览器即可访问企业内网资源，适用于临时访问或仅需 Web 资源访问的场景；
- 客户端 IP 接入模式：用户需要安装 VPN 客户端（如 iNode），通过客户端连接到防火墙，并从 VPN 地址池中获取 IP 地址。适用于需要完整网络访问权限的场景，如

远程办公或全球办公室。

随着远程办公和移动办公的普及，SSL VPN 技术将继续发挥重要作用。未来，SSL VPN 将更加注重用户体验、安全性和性能优化，同时与零信任架构（Zero Trust）等新兴技术深度融合，为企业提供更安全、更灵活的远程接入解决方案。

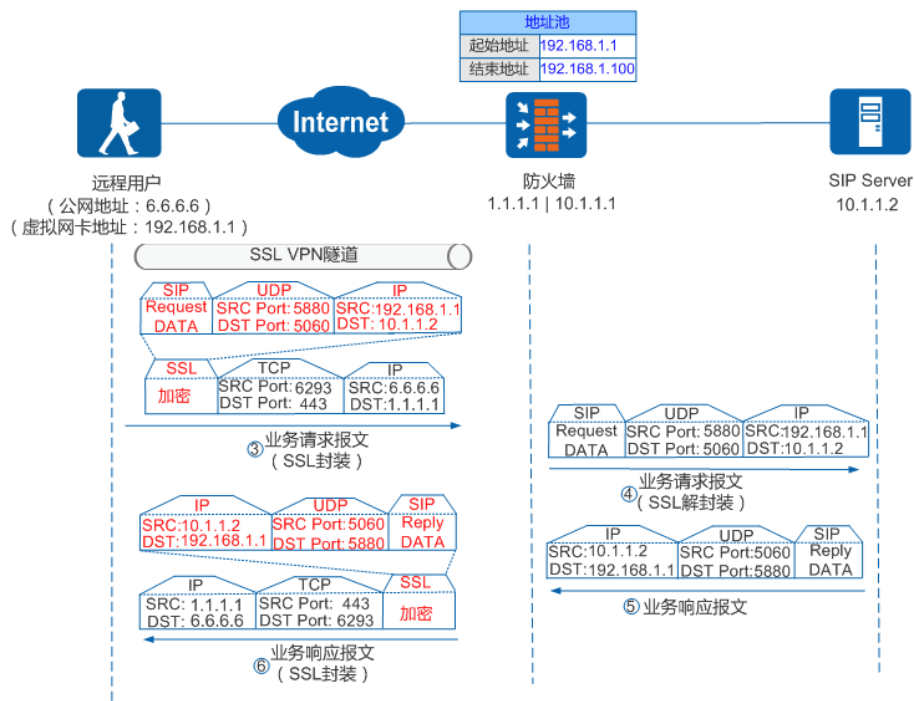


图 1 SSL VPN 的工作原理图

图 1 给出了一个典型的 SSLVPN 的工作原理图，远程用户与内部网络的 SIP 服务器的通信，完全被封装在一个 SSL 隧道中传输，内容是加密的，所以在公网中也是安全的。

5.4 实验环境与分组

H3C F1000 防火墙设备 1 台，交换机 1 台，PC 机 5 台。

每组 4-5 名同学，每人一台 PC，协同进行实验。

5.5 实验步骤

5.5.1 实验拓扑结构

图 2 给出了组网图，交换机只做直连使用，无需配置。图中的参数只作为参考，鼓励各小组灵活自定义 IP 等参数。

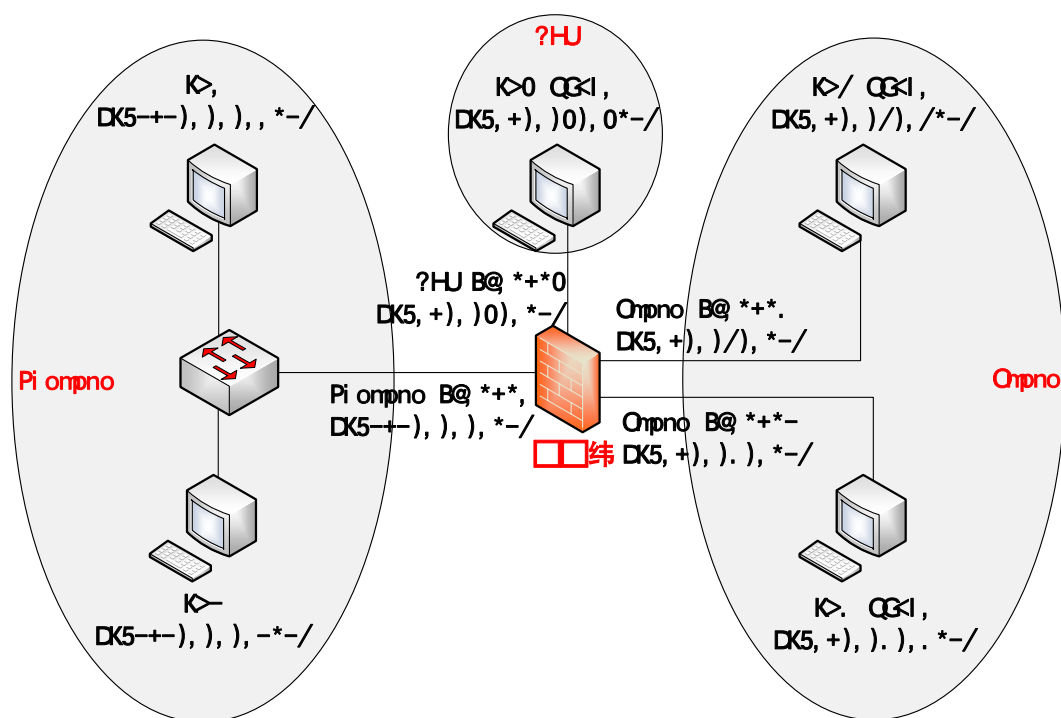


图 2 防火墙实验组网图

5.5.2 安全域配置

防火墙登录用户名及密码均为 **admin**。

查看防火墙当前配置，如果有残留配置信息，需恢复出厂设置，参考命令如下：

```
<F1000>display current-configuration    !显示当前配置
<F1000>reset saved-configuration        !重置保存的配置
The saved configuration file will be erased. Are you sure? [Y/N]:
Before pressing ENTER you must choose 'YES' or 'NO'[Y/N]:Y    !确认重置
Configuration file does not exist!
< F1000-1>reboot    !重启设备
Start to check configuration with next startup configuration file, please wait.....DONE!
Current configuration may be lost after the reboot, save current configuration?[Y/N]:
Before pressing ENTER you must choose 'YES' or 'NO'[Y/N]:N    !不保存当前配置
This command will reboot the device. Continue? [Y/N]:
Before pressing ENTER you must choose 'YES' or 'NO'[Y/N]:Y    !确认重启
.....
<H3C>system-view
[H3C]sysname F1000
[F1000]
```

步骤 1： 配置接口及安全域。

根据组网图中规划的信息，配置各接口的 IP 地址，参考命令如下：

```
[F1000] interface G1/0/1
[F1000-GigabitEthernet1/0/1] ip address 202.1.1.1 255.255.255.0
[F1000-GigabitEthernet1/0/1] quit
```

请参考以上命令配置其他接口的 IP 地址。

配置好接口后，查看并记录防火墙路由表，测试各 PC 机能否通信。

```
[F1000] display ip routing-table
```

根据组网图中规划的信息，将接口加入对应的安全域，参考命令如下：

```
[F1000] security-zone name untrust
[F1000-security-zone-Untrust] import interface gigabitethernet 1/0/1
[F1000-security-zone-Untrust] quit
[F1000] security-zone name trust
[F1000-security-zone-Trust] import interface gigabitethernet 1/0/2
[F1000-security-zone-Trust] import interface gigabitethernet 1/0/3
[F1000-security-zone-Trust] quit
[F1000] security-zone name dmz
[F1000-security-zone-DMZ] import interface gigabitethernet 1/0/5
[F1000-security-zone-DMZ] quit
```

步骤 2：创建访问策略。

允许信任区（内网）访问非信任区（外网）：规则 Pass_Trust_to_Untrust：由 Trust 到 Untrust，允许（pass）：

```
[F1000]security-policy ip
[F1000-security-policy-ip] rule name Pass_Trust_to_Untrust
[F1000-security-policy-ip-0- Pass_Trust_to_Untrust] source-zone Trust
[F1000-security-policy-ip-0- Pass_Trust_to_Untrust] destination-zone Untrust
[F1000-security-policy-ip-0- Pass_Trust_to_Untrust] action pass
[F1000-security-policy-ip-0- Pass_Trust_to_Untrust] quit
[F1000-security-policy-ip]
```

允许外网 IP（202.1.1.12）、内网网段（10.1.3.0）访问 DMZ（隔离区）：

```
[F1000-security-policy-ip] rule name Pass_Untrust_Trust_to_DMZ
[F1000-security-policy-ip-1-Pass_Untrust_Trust_to_DMZ] source-ip-host
202.1.1.12
[F1000-security-policy-ip-1-Pass_Untrust_Trust_to_DMZ] source-ip-subnet
10.1.3.0 255.255.255.0
[F1000-security-policy-ip-1-Pass_Untrust_Trust_to_DMZ] destination-zone DMZ
[F1000-security-policy-ip-1-Pass_Untrust_Trust_to_DMZ] action pass
```

禁止内网访问外网 IP（202.1.1.11）：

```
[F1000-security-policy-ip] rule name Drop_Trust_to_Untrust
[F1000-security-policy-ip-2-Drop_Trust_to_Untrust] source-zone Trust
[F1000-security-policy-ip-2-Drop_Trust_to_Untrust] destination-ip-host 202.1.1.11
[F1000-security-policy-ip-2-Drop_Trust_to_Untrust] action drop
```

步骤 3：测试各网段互联互通情况。

内网仍然可以 ping 通 202.1.1.11，策略 Drop_Trust_to_Untrust 没有起作用，查看策略列表：

```
[F1000-security-policy-ip]dis security-policy ip
```

```
[H3C-security-policy-ip]dis security-policy ip
Security-policy ip

rule 0 name Pass_Trust_to_Untrust
  action pass
  source-zone Trust
  destination-zone Untrust

rule 1 name Pass_Untrust_Trust_to_DMZ
  action pass
  destination-zone DMZ
  source-ip-host 202.1.1.12
  source-ip-subnet 10.1.3.0 255.255.255.0

rule 2 name Drop_Trust_to_Untrust
  action drop
  source-zone Trust
  destination-ip-host 202.1.1.11
```

策略按顺序匹配，rule 0 已经允许，需要将 rule 2 调整到前面：

```
[F1000-security-policy-ip] move rule 2 before 0
```

```
[F1000-security-policy-ip] dis security-policy ip
```

```
Security-policy ip

rule 2 name Drop_Trust_to_Untrust
  action drop
  source-zone Trust
  destination-ip-host 202.1.1.11

rule 0 name Pass_Trust_to_Untrust
  action pass
  source-zone Trust
  destination-zone Untrust

rule 1 name Pass_Untrust_Trust_to_DMZ
  action pass
  destination-zone DMZ
  source-ip-host 202.1.1.12
  source-ip-subnet 10.1.3.0 255.255.255.0
```

再次测试内网能否 ping 通 202.1.1.11。

5.5.3 NAT 配置

安全需求：内网（10.1.3.0/24）访问外网时，将地址映射为 202.1.1.100-120 段地址后再访问；内网服务器（http://10.1.5.15:80）通过地址及接口转换（http://202.1.1.99:888）后，供

外网访问，隐藏内部信息，确保安全。

步骤 4: NAT 配置。

创建 NAT 地址池：

```
[F1000] nat address-group 1
[F1000-address-group-1] address 202.1.1.100 202.1.1.120
[F1000-address-group-1] quit
```

配置 ACL（用于匹配需要 NAT 转换的流量：内网 10.1.3.0/24 网段）：

```
[F1000] acl number 2000
[F1000-acl-basic-2000] rule permit source 10.1.3.0 0.0.0.255
[F1000-acl-basic-2000] quit
```

在接口上配置源 NAT：

```
[F1000] interface G1/0/1
[F1000-GigabitEthernet0/0/1] nat outbound 2000 address-group 1
```

在接口上配置目的 NAT：

```
[F1000-GigabitEthernet0/0/1] nat server protocol tcp global 202.1.1.99 888 inside
10.1.5.15 80
[F1000-GigabitEthernet0/0/1] quit
```

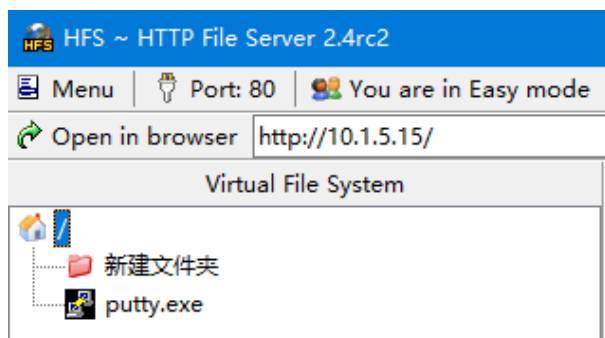
配置完成后，可以通过以下命令查看 NAT 配置和状态。

```
#查看 NAT 地址池
[F1000] display nat address-group
#查看 NAT 会话：
[F1000] display nat session
#查看 NAT Server 配置：
[F1000] display nat server
```

步骤 5: 验证 NAT 配置。

PC3 ping PC2，抓包查看 NAT 是否成功。

在 PC5 打开 HFS，配置 http://10.1.5.15:80 的 web 服务（如果地址不对，通过 Menu->IP address 修改）。



在 PC2 和 PC5 抓包，PC2 通过地址 http://202.1.1.99:888 访问 PC5 的 web 服务，查看数据包源地址、目的地址及端口号等。

5.5.4 SSL VPN 配置

安全需求：内网 PC4 提供 web 服务（http://10.1.4.14），仅允许外网通过 SSL VPN 的 Web 接入方式访问；允许外网通过 SSL VPN 的客户端 IP 接入方式访问内网 10.1.3.0/24 网段。

步骤 6：SSL VPN 配置。

取消接口 G1/0/1 的 NAT 配置：

```
[F1000] interface GigabitEthernet1/0/1
[F1000-GigabitEthernet1/0/1] undo nat outbound 2000
[F1000-GigabitEthernet1/0/1] undo nat server protocol tcp global 202.1.1.99 888
[F1000-GigabitEthernet1/0/1] quit
```

创建规则，允许 Untrust、Local 和 Trust 的访问：

```
[F1000] security-policy ip
[F1000-security-policy-ip] rule name Pass_Untrust_to_Local
[F1000-security-policy-ip-3-Pass_Untrust_to_Local] action pass
[F1000-security-policy-ip-3-Pass_Untrust_to_Local] source-zone Untrust
[F1000-security-policy-ip-3-Pass_Untrust_to_Local] destination-zone Local
[F1000-security-policy-ip-3-Pass_Untrust_to_Local] quit
[F1000-security-policy-ip] rule name Pass_Local_to_Trust
[F1000-security-policy-ip-4-Pass_Local_to_Trust] action pass
[F1000-security-policy-ip-4-Pass_Local_to_Trust] source-zone Local
[F1000-security-policy-ip-4-Pass_Local_to_Trust] destination-zone Trust
[F1000-security-policy-ip-4-Pass_Local_to_Trust] quit
[F1000-security-policy-ip]
```

配置 SSL VPN：

```
#创建 SSL VPN IP 接入接口 SSLVPN-AC1，加入到 Untrust（非信任区）
[F1000] interface SSLVPN-AC1
[F1000-SSLVPN-AC1] ip address 4.4.4.1 255.255.255.0
[F1000-SSLVPN-AC1] security-zone name Untrust
[F1000-security-zone-Untrust] import interface SSLVPN-AC1
[F1000-security-zone-Untrust] quit
#创建 ACL 允许 IP
[F1000] acl advanced 3000
[F1000-acl-ipv4-adv-3000] rule 0 permit ip
[F1000-acl-ipv4-adv-3000] quit
#创建 VPN 地址池 ippool1
[F1000] sslvpn ip address-pool ippool1 4.4.4.10 4.4.4.20
#创建 VPN 网关 sslvpnGW
```

```
[F1000] sslvpn gateway sslvpnGW
[F1000-sslvpn-gateway-sslvpnGW] ip address 202.1.1.1 port 2000
[F1000-sslvpn-gateway-sslvpnGW] service enable
[F1000-sslvpn-gateway-sslvpnGW] quit
#创建访问实例 vpnC
[F1000] sslvpn context vpnC
[F1000-sslvpn-context-vpnC] gateway sslvpnGW
[F1000-sslvpn-context-vpnC] ip-tunnel interface SSLVPN-AC1
[F1000-sslvpn-context-vpnC] ip-tunnel address-pool ippool1 mask 255.255.255.0
#创建路由列表 rtlist (IP 接入访问网段路由)
[F1000-sslvpn-context-vpnC] ip-route-list rtlist
[F1000-sslvpn-context-vpnC-route-list-rtlist] include 10.1.3.0 255.255.255.0
#创建资源列表 urllist (web 接入访问资源 http://10.1.4.14)
[F1000-sslvpn-context-vpnC-route-list-rtlist] url-item urllist
[F1000-sslvpn-context-vpnC-url-item-urllist] url http://10.1.4.14
[F1000-sslvpn-context-vpnC-url-item-urllist] url-list urllist
[F1000-sslvpn-context-vpnC-url-list-urllist] resources url-item urllist
#创建资源组 rsourceG
[F1000-sslvpn-context-vpnC-url-list-urllist] policy-group rsourceG
[F1000-sslvpn-context-vpnC-policy-group-rsourceG] filter ip-tunnel acl 3000
[F1000-sslvpn-context-vpnC-policy-group-rsourceG] ip-tunnel access-route ip-route-list
rtlist
[F1000-sslvpn-context-vpnC-policy-group-rsourceG] ip-tunnel address-pool ippool1 mask
255.255.255.0
[F1000-sslvpn-context-vpnC-policy-group-rsourceG] resources url-list urllist
[F1000-sslvpn-context-vpnC-policy-group-rsourceG] force-logout max-onlines enable
[F1000-sslvpn-context-vpnC] service enable
#创建 VPN 用户
[F1000] local-user user1 class network
[F1000-luser-network-user1] password simple user1
[F1000-luser-network-user1] service-type sslvpn
[F1000-luser-network-user1] authorization-attribute user-role network-operator
[F1000-luser-network-user1] authorization-attribute sslvpn-policy-group rsourceG
[F1000-luser-network-user1] local-user user2 class network
[F1000-luser-network-user2] password simple user2
[F1000-luser-network-user2] service-type sslvpn
[F1000-luser-network-user2] authorization-attribute user-role network-operator
[F1000-luser-network-user2] authorization-attribute sslvpn-policy-group rsourceG
```

```
[F1000-luser-network-user2] quit
#创建非信任区仅 VPN 地址段 4.4.4.0 可访问信任区规则
[F1000] security-policy ip
[F1000-security-policy-ip] rule name Pass_Untrust_to_Trust
[F1000-security-policy-ip-5-Pass_Untrust_to_Trust] action pass
[F1000-security-policy-ip-5-Pass_Untrust_to_Trust] source-ip-subnet 4.4.4.0 255.255.255.0
[F1000-security-policy-ip-5-Pass_Untrust_to_Trust] destination-zone Trust
[F1000-security-policy-ip-5-Pass_Untrust_to_Trust] quit
[F1000-security-policy-ip] quit
```

步骤 7：SSL VPN Web 接入测试。

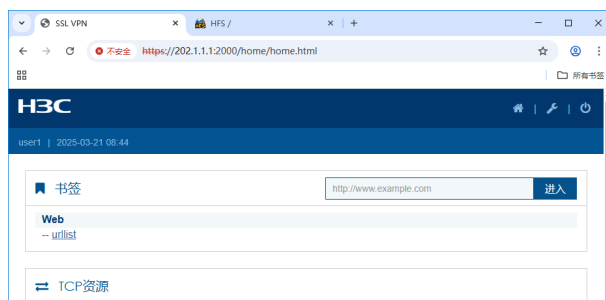
在 PC4 打开 HFS，创建链接为 <http://10.1.4.14:80> 的 web 服务。

在 PC1 和 PC4 开始抓包监听。

PC1 在浏览器地址栏输入防火墙地址 <https://202.1.1.1:2000>（如果提示不安全，选择高级->继续访问），在登录界面输入用户 **user1** 及密码，点击登录；



登录成功后，点击“Web”中的资源列表，或者在右侧框中输入地址“<http://10.1.4.14>”访问内网资源。



访问成功后，停止抓包，分析 Web 接入的访问过程，注意观察两侧数据包的源地址、目的地址、端口号、是否加密等。

步骤 8：SSL VPN 客户端接入测试。

在 PC3 打开 HFS，创建链接为 <http://10.1.3.13:80> 的 Web 服务。

在 PC2 安装 iNode 客户端软件，安装完成后，本地网络连接中会出现一个虚拟网卡，如“以太网 2 iNode VPN Virtual NIC”。



在 PC2 和 PC3 上开始抓包监听，PC2 需同时在 exp 网卡和**虚拟网卡**上抓包监听。

打开桌面“iNode 智能客户端”，输入网关地址 202.1.1.1:2000，点击刷新显示出登录框，输入用户名 user2 及密码，点击连接。



连接成功后，在 PC2 浏览器输入 <http://10.1.3.13>，看能否访问。

在 cmd 执行 ping 10.1.3.13 命令，看能否 ping 通。

点击 iNode 客户端右下角设置图标，打开“管理平台->网卡信息”，或者在本地网络连接中查看虚拟网卡的 IP 地址。



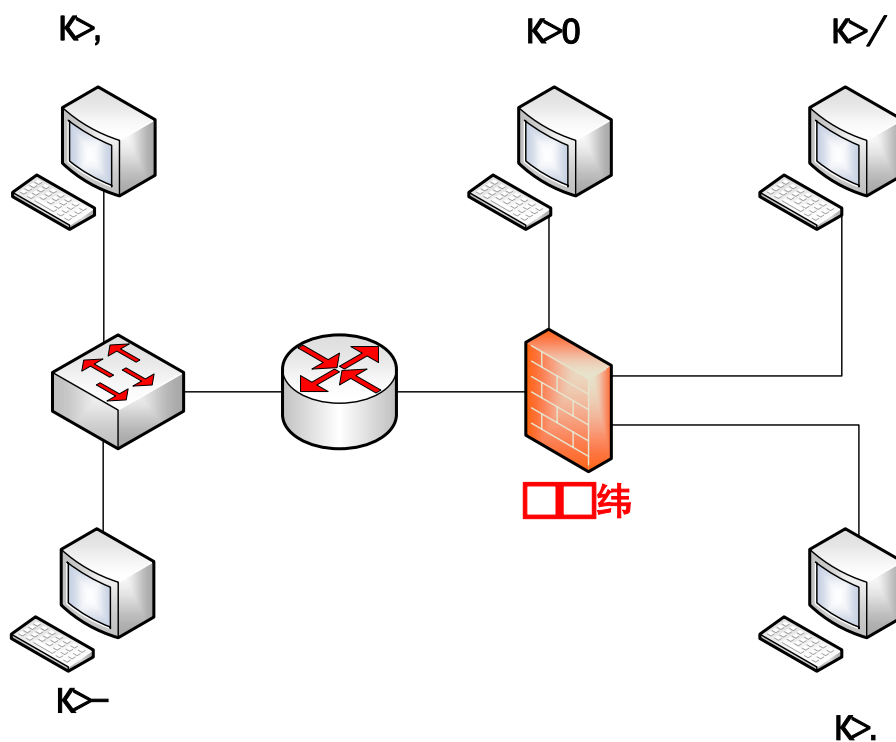
查看 PC2 的路由表，标记出虚拟网卡对应的路由条目（参考命令：route print）。

结合 PC2 和 PC3 上抓到的数据包分析客户端模式的访问过程（虚拟网卡的作用）。

分析几种模式访问内部资源（内网访问、外网 web 模式、外网客户端模式）的差别，解释外部 PC 通过 VPN 访问内网的安全性。

5.6 进阶自设计

1) 在基础实验的基础上,外网与防火墙之间增加一个路由器,实现跨网段的 SSLVPN 接入。



2) 分别在校园网和外网（通过校园 VPN 服务 <http://vpn.xjtu.edu.cn/>）访问校内资源，通过抓包分析对比三种模式（内网访问、外网 WebVPN 访问和外网 SSLVPN 访问）的访问过程及相关参数（物理网卡/虚拟网卡参数、路由表、通信协议、数据包源/目的地址等）。